

Explicación de Cross-Site Request Forgery (CSRF)

El **Cross-Site Request Forgery (CSRF)**, o Falsificación de Peticiones en Sitios Cruzados, es un tipo de ataque donde un atacante engaña al navegador de un usuario **autenticado** para que envíe una solicitud HTTP no deseada a una aplicación web.

El Problema de CSRF (Dependencia de Cookies)

El ataque CSRF solo funciona porque los navegadores tienen una regla fundamental:

Al hacer una solicitud a un dominio (ejemplo: tuecommerce.com), el navegador adjunta automáticamente todas las cookies de sesión asociadas a ese dominio, sin importar de dónde provenga la solicitud.

Esta cookie de sesión es la prueba que le dice al servidor: "Esta solicitud viene del usuario autenticado". El atacante se aprovecha de esta automatización para enviar una solicitud forzada que parece legítima.

La Solución JWT (*Tokens* en el *Header*)

En una arquitectura con JWT para APIs REST, la autenticación no utiliza *cookies* de sesión. En su lugar, utiliza el patrón **Token Portador (Bearer Token)**:

Característica	Autenticación con <i>Cookies</i> (Vulnerable a CSRF)	Autenticación con JWT (Inmune a CSRF)
Prueba de Identidad	Se almacena en una Cookie de Sesión .	Se almacena en un JSON Web Token (JWT) .
Ubicación en la Solicitud	La cookie se envía automáticamente en el <i>header</i> de la solicitud por el navegador.	El JWT se envía manualmente en un <i>header</i> HTTP llamado Authorization: Bearer <token> .
El Secreto del Ataque	El atacante no necesita conocer la cookie porque el navegador la adjunta por él.	El atacante necesita conocer y enviar el <i>token</i> JWT.

En una API REST sin estado (stateless) que utiliza JWT para la autenticación (enviado en el header Authorization: Bearer), es necesario incluir la línea `csrf(csrf -> csrf.disable())` en tu configuración de Spring Security.

La clave del problema es:

El navegador web incluye automáticamente las *cookies* de sesión (que prueban que estás logueado) en todas las solicitudes que envías al dominio, sin importar de dónde provenga la solicitud.

Mecanismo Simple:

1. **Víctima Autenticada:** Inicias sesión en tu e-commerce (sitio-legitimo.com). El sitio te da una **cookie de sesión**.
2. **Ataque Engañoso:** Un atacante te envía un enlace, un correo o te engaña para que visites su sitio malicioso (sitio-malicioso.com).
3. **Ejecución Silenciosa:** El sitio malicioso contiene código (a menudo una imagen oculta o un formulario automático) que fuerza a tu navegador a enviar una solicitud a sitio-legitimo.com.
4. **Engaño al Servidor:** Tu navegador adjunta automáticamente la cookie de sesión válida. El servidor de sitio-legitimo.com cree que la solicitud viene de ti (el usuario legítimo) y la ejecuta.